

1.- Análisis del Escenario y Objetivos

1.1.- Contexto

Tras realizar una auditoría técnica en la "**Librería Digital Iván Barranco**", se ha determinado que la infraestructura actual es crítica, vulnerable y totalmente ineficiente para soportar el crecimiento de ventas online.

Los **principales problemas detectados** son:

- **Red Insegura y Plana:** Ausencia total de segmentación; los ordenadores de contabilidad y recursos humanos conviven en la misma red que el servidor web público, lo que implica un riesgo alto de fuga de datos sensibles.
- **Exposición Directa al Exterior:** La tienda online carece de seguridad perimetral avanzada (WAF o IDS), facilitando ataques de denegación de servicio o inyección SQL.
- **Vulnerabilidad Crítica de los Servidores:** Inexistencia de orquestación moderna. Si el servidor web cae, la tienda deja de vender (pérdida económica directa) por falta de autorrecuperación.
- **Ausencia de Gestión Centralizada de Identidades:** Administración local de equipos, dificultando el control de acceso de los empleados al inventario y facturación.
- **Inexistencia de Backups Inmutables:** Riesgo de pérdida del catálogo de libros y base de datos de clientes ante un ataque de Ransomware.
- **Ceguera Tecnológica:** No existe monitorización activa; no se detectan intentos de intrusión hasta que es demasiado tarde.

1.2.- Objetivos

1.2.1. Segmentación de Red y Seguridad Perimetral

Diseñar e implementar un firewall central (**pfSense**) con **cuatro interfaces lógicas** (VLANs/Túneles) para aislar el tráfico según su función:

- **WAN:** Conexión a Internet y punto de entrada para clientes.
- **DMZ (VLAN 10):** Servicios expuestos (Tienda Web y API de libros).
- **LAN Interna (VLAN 20):** Red de gestión para empleados y administración.
- **SOC (VLAN 30):** Red dedicada exclusivamente a la monitorización y seguridad.

1.2.2. ZONA DMZ

Existirá un nodo servidor que proporciona la tienda online al exterior. Las aplicaciones utilizan **tecnología de contenedores y orquestación (Kubernetes K3s)** para garantizar la alta disponibilidad.

- **Ejemplos:**
 - **Tienda Web:** Despliegue en Pods con réplicas automáticas.
 - **Ingress Controller:** Enrutador de tráfico web seguro (HTTPS).
 - **Base de Datos:** MariaDB en modo StatefulSet (aislada en la red interna del clúster).

1.2.3. ZONA LAN interna

En este segmento de red se centralizarán los recursos de la oficina.

A. Servicios de Infraestructura Local

- **Gestión Centralizada (Active Directory):** Implementar Windows Server para la gestión de usuarios (empleados de la librería), y aplicación de políticas de seguridad (GPOs) para restringir USBs o instalaciones de software.
- **Configuración Dinámica (DHCP):** Control automático de IPs para los equipos de oficina.

B. Roles y Accesos

- **Equipos de Usuarios:** Los puestos de los empleados tendrán acceso restringido, pudiendo consultar el stock y facturación, pero sin acceso directo a los servidores de la DMZ.
- **Equipos Técnicos (Administradores):** Dispondrán de herramientas para:
 - **Automatización:** Gestión del clúster K3s mediante ficheros YAML.
 - **Copias de Seguridad:** Gestión de respaldos híbridos (**AWS**) para garantizar la recuperación del catálogo ante desastres.

Medidas de seguridad: Detección, Hardening y Control Perimetral.

Servidor	¿Qué securizamos?	Concepto clave
Principal (PfSense)	El perímetro, VPN y tráfico entre VLANs	IDS/IPS (Suricata): Detección de intrusos y bloqueo de IPs maliciosas.
Web (DMZ - K3s)	La tienda online y la base de datos	Ingress Controller + WAF: Filtrado de ataques web (SQLi, XSS) antes de llegar a la App.

Local (AD)	Las identidades y accesos internos	GPO (Políticas de Grupo): Bloqueo de escritorio, contraseñas robustas y logs de auditoría.
-------------------	------------------------------------	---

Monitorización: Supervisión constante de los servidores (Stack Wazuh + Grafana)

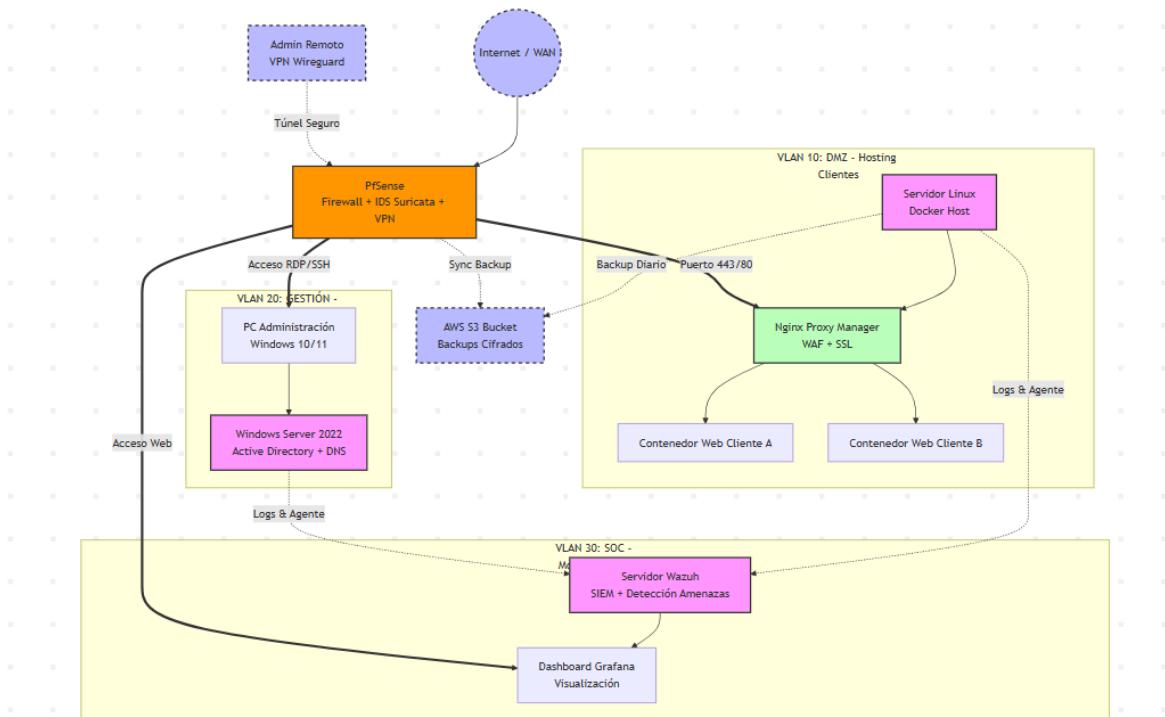
Servidor	¿Qué monitorizamos?	Indicadores Clave (Métricas)
Principal (PfSense)	Tráfico y Conectividad	Ancho de banda WAN, bloqueo de paquetes y estado del túnel VPN WireGuard.
Web (DMZ)	Disponibilidad de la Tienda	Estado de los Pods de Kubernetes, uso de CPU del nodo y códigos HTTP (200 OK / 500 Error).
Local (AD)	Seguridad Interna	Intentos de inicio de sesión fallidos (Fuerza bruta) y creación de usuarios sospechosos.

Los administradores utilizarán la **VPN WireGuard** del Servidor Principal para administrar la red desde el exterior de forma segura.

2.- Diseño físico y lógico de la infraestructura

2.1.- Diseño físico

A. Mapa de Red (completo)



Elementos obligatorios en el diagrama:

- **Servidor Central (PfSense):** Con sus interfaces (WAN, DMZ, LAN, SOC).
- **Nodo K3s (DMZ):** Conectado al Switch-DMZ.
- **Servidor AD (LAN):** Conectado al Switch-LAN.
- **Servidor Wazuh (SOC):** Conectado al Switch-SOC.
- **Nube AWS:** Conectada lógicamente para los backups.

B. Entorno de Implementación Se utilizará la plataforma de virtualización **VirtualBox** debido a su compatibilidad con el entorno de laboratorio académico. Para que el diseño funcione, la configuración de conectividad será la siguiente:

Interfaz / Servidor	Conectada a	Modo de Red (Software)	Servicios

Srv-Firewall (Eth0)	WAN / Internet	Adaptador Puente / NAT	Salida a Internet y entrada VPN.
Srv-Firewall (Eth1)	Switch-DMZ	Red Interna "DMZ"	Gateway para la tienda online (172.16.10.1).
Srv-Firewall (Eth2)	Switch-LAN	Red Interna "LAN"	Gateway para la oficina (10.0.20.1).
Srv-Firewall (Eth3)	Switch-SOC	Red Interna "SOC"	Gateway para monitorización (192.168.30.1).
Srv-K3s (Eth0)	Switch-DMZ	Red Interna "DMZ"	Nodo Kubernetes y Tienda Web.
Srv-AD (Eth0)	Switch-LAN	Red Interna "LAN"	Controlador de Dominio y DNS interno.
Srv-Wazuh (Eth0)	Switch-SOC	Red Interna "SOC"	Servidor SIEM (Wazuh).

C. Características de los servidores

Recurso	Srv-Firewall (PfSense)	Srv-Web (Nodo K3s)	Srv-Local (AD 2022)
Enfoque técnico	Seguridad y Routing	Orquestación Contenedores	Gestión Usuarios
S.O.	FreeBSD (PfSense CE)	Linux (Debian/Ubuntu)	Windows Server 2022

CPU	2 vCPU	2 - 4 vCPU	2 vCPU
RAM	2 GB	4 - 8 GB	4 GB
Disco	20 GB SSD	50 GB SSD	60 GB SSD
Otras carac.	IDS Suricata + WireGuard	Docker + K3s + Python	DNS + DHCP

2.2. Diseño lógico

En este apartado se define el plan de direccionamiento IP para la **Librería Digital**, permitiendo la comunicación controlada por el firewall entre las zonas.

Cuadro de direccionamiento IP:

Zona / Interfaz	Dispositivo / Servidor	Red (ID de red)	Máscara	IP Fija (Host)
WAN (NIC 1)	Srv-Firewall (PfSense)	(Asignada por ISP/Lab)	/24	DHCP / Estática
DMZ (NIC 2)	Srv-Firewall (Gateway)	172.16.10.0	/24	172.16.10.1
DMZ (NIC 3)	Srv-K3s (Tienda Web)	172.16.10.0	/24	172.16.10.10
LAN (NIC 1)	Srv-Firewall (Gateway)	10.0.20.0	/24	10.0.20.1
LAN (NIC 1)	Srv-AD (Active Directory)	10.0.20.0	/24	10.0.20.20

SOC (NIC 1)	Srv-Firewall (Gateway)	192.168.30.0	/24	192.168.30.1
SOC (NIC 1)	Srv-Wazuh (Monitorización)	192.168.30.0	/24	192.168.30.30